

Phase 002 - CSP and UI Hygiene Gate

Generated: 2026-05-07T16:48:25-04:00

Result

Phase 002 status: ****PARTIAL PASS.****

The CSP auth-provider fix was implemented, tested, built, deployed to production, and verified in live response headers. Full Phase 002 acceptance is not complete because owner-authenticated browser console smoke remains blocked by the unavailable owner/admin session, and the broader live UI contract audit surfaced one existing Build-Wiki Run Now contract mismatch that belongs to the no-fake-buttons/security gate.

Code Changes

```
| File | Change |
| --- | --- |
| `src/lib/csp.ts` | Added explicit auth-provider CSP model. Google origins are included only when Google auth is configured; Microsoft/Entra origins are included only when Entra auth is configured. |
| `src/proxy.ts` | Replaced duplicated env checks with CSP provider helpers and passed Google/Microsoft flags into the nonce CSP headers. |
| `src/lib/__tests__/csp.test.ts` | Added coverage for Google and Microsoft auth-provider CSP origins. |
```

Live Production Header Proof

Production `/login` now returns a CSP that includes:

```
script-src ... https://accounts.google.com
style-src-elem ... https://accounts.google.com
connect-src ... https://accounts.google.com
frame-src ... https://accounts.google.com
form-action self
```

Microsoft/Entra origins were not present in the live header because Entra auth is not configured in the current production environment. The CSP builder includes them when the required Entra configuration is present.

Checks Run

```
| Check | Result |
| --- | --- |
| CSP unit tests | PASS: 3 tests |
| Gateway security proof tests | PASS: 4 tests |
| Gateway operator contract tests | PASS: 4 tests |
| Typecheck | PASS |
| Production build | PASS |
| Mission Control restart | PASS via process termination/service restart fallback; `systemctl restart` itself required interaction |
| Post-restart core route smoke | PASS: Gateway, Agent Hub, Agent Zero status, Hermes status all returned 200 with auth |
| Live CSP header smoke | PASS |
| Broader button/action live audit | FAIL: existing Build-Wiki Run Now endpoint returned 201 approval-request behavior during smoke test |
```

Restart Proof

```
| Item | Value |
| --- | --- |
| Old Mission Control PID | `1637871` |
| New Mission Control PID | `1897577` |
| New restart timestamp | `Thu 2026-05-07 16:47:01 EDT` |
| Service state | `active` |
```

Existing Issue Surfaced During UI Hygiene

The live button/action audit reported:

```
| Endpoint | Result | Concern |
| --- | --- | --- |
| `POST /api/bridge/brain-sync/build-wiki/run-now` | HTTP 201 | Conservative audit marks this as `endpoint_enabled_execution_will_succeed` |
```

Owner-Authenticated Browser Limitation

Phase 002 cannot prove the authenticated owner browser has zero console errors because Phase 001 remains blocked by missing owner/admin browser session. This is not being marked as passed or faked.

Security Confirmation

- No secrets were printed.
- No `.env`` files were modified.
- No auth bypass or auth weakening was performed.
- No public exposure was added.
- No Zapier write was run.
- No HeyGen generation was run.
- No SMB mount or Fork 2 action occurred.
- No farmer execution occurred.
- OpenCloud and Build-Wiki/Farmer were not deleted or disabled.

Next Step

Proceed to Phase 003 Agent Zero final commander proof, while carrying forward two UI/security blockers:

1. owner-authenticated browser console smoke still needs a real owner/admin session;
2. Build-Wiki Run Now route/UI contract needs Phase 027 no-fake-buttons cleanup.

Rollback

Rollback command after commit: ``git revert <phase-002-commit>``.